RUNNING EXAMPLE

We use CVE-2013-5029 (a *clickjacking*-related vulnerability in *phpMyAdmin*) as a running example to illustrate how COMPASS analyzes a real-world vulnerability with multiple patches and infers their relationships.

1 The example vulnerability and its patches

1.1 The description for the vulnerability

The vulnerability recorded in CVE-2013-5029 affects *phpMyAdmin* 3.5.x and 4.0.x before 4.0.5, where remote attackers can bypass the *clickjacking* protection mechanism via vectors related to *Header.class.php*. The description is as follows:

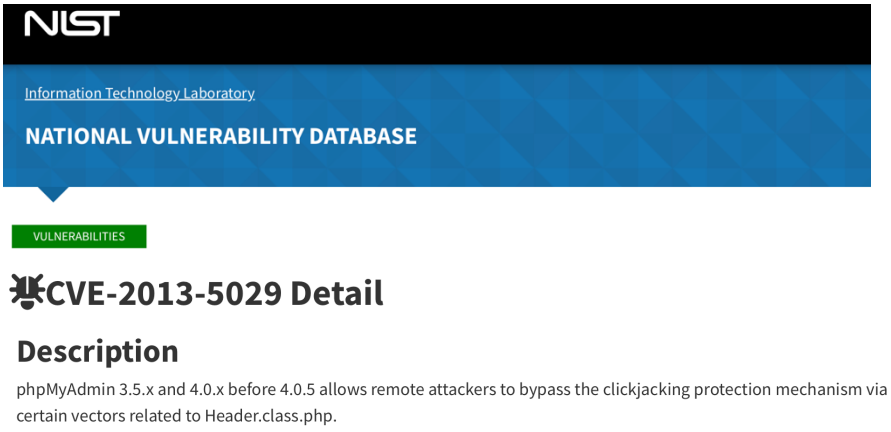


Figure 1. The description for CVE-2013-5029

1.2 The patches of this vulnerability

Its four patches **are indicated by the NVD platform** as follows:

- ***240b833***2db53dedc27baeec5306dabad3bdece3b
- ***24d0eb5***5203b029f250c77d63f2900ffbe099e8b
- ***66fe475***d4f51b1761719cb0cab360748800373f7
- ***da4042f***b6c4365dc8187765c3bf525043687c66f

URL	Source(s)	Tag(s)
http://lists.opensuse.org/opensuse-security-announce/2013-08/msg00013.html	CVE, MITRE	
http://secunia.com/advisories/54488	CVE, MITRE	Vendor Advisory
http://www.phpmyadmin.net/home_page/security/PMASA-2013-10.php	CVE, MITRE	Vendor Advisory
https://github.com/phpmyadmin/phpmyadmin/commit/240b8332db53dedc27baeec5306dabad3bdece3b	CVE, MITRE	Exploit Patch
https://github.com/phpmyadmin/phpmyadmin/commit/24d0eb55203b029f250c77d63f2900ffbe099e8b	CVE, MITRE	Exploit Patch
https://github.com/phpmyadmin/phpmyadmin/commit/66fe475d4f51b1761719cb0cab360748800373f7	CVE, MITRE	Patch
https://github.com/phpmyadmin/phpmyadmin/commit/da4042fb6c4365dc8187765c3bf525043687c66f	CVE, MITRE	Exploit Patch

Figure 2. The patches of the vulnerability of CVE-2013-5029

We give the commit messages and code changes of the four patches, as shown in Figure 3 ~ Figure 6, for facilitating readers' understanding (the detailed information of the patches can be available by clicking the above hyperlinks).

Commit 240b833

nijel committed on Jul 29, 2013

```
Readd AllowThirdPartyFraming option

We want by default no framing of phpMyAdmin, but still some sites might
need to embed it, so configuration option (with appropriate security
warning) is there.

This basically reverts d7e0bed.
```

master · RELEASE_5_2_3 ··· RELEASE_4_0_5RC2

js/cross_framing_protection.js

```
@@ -0,0 +1,14 @@
+ /* vim: set expandtab sw=4 ts=4 sts=4: */
+ /**
+  * Conditionally included if third-party framing is not allowed
+  *
+  */
+
+ try {
+     if (top != self) {
+         top.location.href = self.location.href;
+     }
+ } catch(e) {
+     alert("Redirecting... (error: " + e);
+     top.location.href = self.location.href;
+ }
```

Figure 3. The commit message and partial code changes of Patch *240b833*

Commit `24d0eb5`

nijel committed on Jul 29, 2013

```
Improved protection against cross framing

We now include CSS to hide the page and display it conditionally after
checking we're in top frame. This adds extra protection for clients who
do not support X-Frame-Options.

See also http://en.wikipedia.org/wiki/Framekiller and
https://www.owasp.org/index.php/Clickjacking_Defense_Cheat_Sheet
```

master · RELEASE_5_2_3 ··· RELEASE_4_0_5RC2

2 files changed +6 -10 lines changed

Search within code

js/cross_framing_protection.js +5 -10

```
@@ -1,14 +1,9 @@
/* vim: set expandtab sw=4 ts=4 sts=4: */
/**
- * Conditionally included if third-party framing is not allowed
- *
+ * Conditionally included if framing is not allowed
 */
-
- try {
-     if (top != self) {
-         top.location.href = self.location.href;
-     }
- } catch(e) {
-     alert("Redirecting... (error: " + e);
-     top.location.href = self.location.href;
+ if(self == top) {
+     document.documentElement.style.display = 'block' ;
+ } else {
+     top.location = self.location ;
 }
```

libraries/Header.class.php +1

```
@@ -531,6 +531,7 @@ private function _getMetaTags()
        $retval  = '<meta charset="utf-8" />';
        $retval .= '<meta name="robots" content="noindex,nofollow" />';
        $retval .= '<meta http-equiv="X-UA-Compatible" content="IE=Edge">';
+       $retval .= '<style>html{display: none;}</style>';
        return $retval;
    }
```

Figure 4. The commit message and code changes of Patch *24d0eb5*

Commit `66fe475`

Marc Delisle committed on Jul 30, 2013

```
ChangeLog entry for Improved protection against cross framing
```

master · RELEASE_5_2_3 ··· RELEASE_4_0_5RC2

1 file changed +2 -0 lines changed

ChangeLog

```
@@ -17,6 +17,8 @@ phpMyAdmin - ChangeLog
- bug #4009 Statistic Monitor shows only last 3 digits in graph
- bug #3998 Non-permanent SQL history not working
- bug #3578 Transformations for text/plain on a BLOB column
+ - [security] Improved protection against cross framing, see PMASA-2013-10
+ + Reinstated configuration directive: AllowThirdPartyFraming

4.0.4.2 (2013-07-28)
- [security] Fix stored XSS in Server status monitor, see PMASA-2013-9
```

Figure 5. The commit message and code changes of Patch *66fe475*

Commit da4042f

nijel committed on Jul 30, 2013

Display none only if protection is enabled

master · RELEASE_5_2_3 ··· RELEASE_4_0_5RC2

1 file changed +3 -1 lines changed

libraries/Header.class.php

```
@@ -531,7 +531,9 @@ private function _getMetaTags()
531 531          $retval  = '<meta charset="utf-8" />';
532 532          $retval .= '<meta name="robots" content="noindex,nofollow" />';
533 533          $retval .= '<meta http-equiv="X-UA-Compatible" content="IE=Edge">';
534     -        $retval .= '<style>html{display: none;}</style>';
    534 +        if (! $GLOBALS['cfg']['AllowThirdPartyFraming']) {
    535 +            $retval .= '<style>html{display: none;}</style>';
    536 +        }
535 537          return $retval;
536 538      }
537 539
```

Figure 6. The commit message and code changes of Patch *da4042f*

2 Running of COMPASS

2.1 Phase-1 (Multiple Patch Identification)

COMPASS takes the vulnerability entry (CVE-2013-5029) from the NVD platform as input, which explicitly records links to the patches that fix the vulnerability, allowing the required patch group (Commits *240b833*, *24d0eb5*, *66fe475*, and *da4042f*) to be obtained directly. COMPASS then performs the lightweight pre-scanning step over commit messages to detect explicit relationship evidence. In this case, no relationship instance can be directly determined from explicit message cues, and the patch group is forwarded to the subsequent LLM-based phases.

2.2 Phase-2 (Individual Patch Analysis)

COMPASS prompts the LLM to inspect each patch in isolation, based on the received vulnerability (including the CVE ID "*CVE-2013-5029*" and the description) and its patch group

(including the commit ID, the branch/version information, the commit message, and the code change of Patches *240b833*, *24d0eb5*, *66fe475*, *da4042f*). The analysis finds that Patches *240b833*, *24d0eb5*, and *da4042f* directly contribute to *clickjacking* protection by modifying the framing-related logic in *Header.class.php* and the associated client-side checks. Patch *66fe475* only updates the file *ChangeLog* to record the security fix, without changing any remediation logic. Therefore, *66fe475* is flagged by Patch-Vulnerability Alignment as a non-remediation patch and is not required to participate in relationship inference/output in later phases.

2.3 Phase-3 (Patch Relationship Prediction)

COMPASS next prompts the LLM to infer patch relationship instances among the remaining remediation patches using the hierarchy-guided prompt. Since no *Merge* or *Mirror* signal is present, the LLM focuses on dependency-based reasoning and identifies two relationship instances:

(1) $R_{CVE\text{-}2013\text{-}5029\text{-}\text{“}Collaboration\text{”}}$: {*240b833*: [*24d0eb5*]}

Patch *240b833* alleviates the original *Header.class.php*-related *clickjacking* bypass by introducing initial cross-framing protection and related configuration semantics, involving seven files. While Patch *24d0eb5* further strengthens the protection by adding an additional defensive layer (a *CSS* fail-safe protection layer for enhancing the compatibility of client-side defenses) to one of the files. Importantly, Patch *24d0eb5* is written on top of Patch *240b833*: it explicitly deletes and rewrites the code that Patch *240b833* added in *cross_framing_protection.js*. Therefore, applying Patch *24d0eb5* alone may not match the target code cleanly (or may require manual adjustment), since the code it intends to remove may not exist before Patch *240b833* is applied. Moreover, Patch *24d0eb5* does not subsume

the other *clickjacking*-related changes introduced by Patch *240b833* across the remaining files. Therefore, adopting both patches is necessary to obtain the complete remediation as implemented in the upstream fix. **As a result, Patch *24d0eb5* has a *Collaboration* relationship with Patch *240b833*.**

(2) $R_{CVE\text{-}2013\text{-}5029\text{-}\text{“}Fixing\text{-}of\text{-}Fixing\text{”}}$: {*24d0eb5*: [*da4042f*]}

Patch *24d0eb5* strengthens the *clickjacking* defense by introducing a “hide-then-reveal” strategy (injecting “*html*{*display*: *none*;}” and revealing the page only after a top-frame check). However, it applies this hiding behavior too broadly, which may block legitimate page rendering even when third-party framing is allowed. Patch *da4042f* fixes this flaw by making the “*display*: *none*” injection conditional: it injects “*html*{*display*: *none*;}” only when *AllowThirdPartyFraming* is disabled (i.e., when framing protection is intended to be enforced), thereby preserving the intended remediation while eliminating the introduced side effects. **Thus, Patch *da4042f* has a *Fixing-of-Fixing* relationship with Patch *24d0eb5*.**

2.4 Phase-4 (Validation Check)

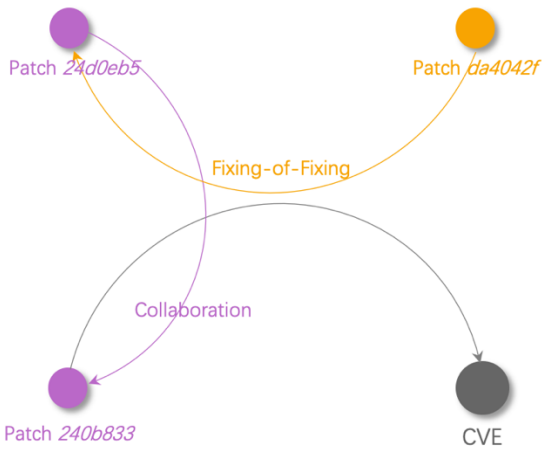
Finally, COMPASS validates the inferred relationship instances. The patch-coverage check confirms that each remediation patch (*240b833*, *24d0eb5*, and *da4042f*) participates in at least one relationship instance, while Patch *66fe475* is exempted as it has been filtered out by Patch-Vulnerability Alignment. The hierarchy-aware constraint check further confirms that the inferred instances conform to Phase-4’s constraints (e.g., no contradictory relationships among different hierarchies).

2.5 Output

COMPASS integrates the reasoning results of the prediction and validation check processes, obtains the relationships of the input patch group. Finally, COMPASS organizes the results into a structured output and visualizes them as a graph for downstream maintainers.

The results are as follows:

[Output of COMPASS]

$R_{CVE\text{-}2013\text{-}5029\text{-}\text{“}Collaboration\text{”}}$: $\{240b833: [24d0eb5]\}$

$R_{CVE\text{-}2013\text{-}5029\text{-}\text{“}Fixing\text{-}of\text{-}Fixing\text{”}}$: $\{24d0eb5: [da4042f]\}$